# Securing Microsoft Azure AD Connect

trimarcsecurity.com/hub-post/securing-microsoft-azure-ad-connect

Scott Blake October 28, 2020

Updated: Dec 13, 2024

With more and more organizations moving to the cloud, specifically Azure Active Directory/Microsoft 365 (formerly Office 365), Trimarc has seen a large increase in the number of Azure AD Connect deployments during our Active Directory Security Assessments (ADSAs). With this growing trend of hybrid-cloud implementations it is vital for organizations to get the security right on the Azure AD Connect components (i.e. server, service account, and database).

Azure AD Connect allows for an on-prem Active Directory forest to synchronize data with (Microsoft provided cloud directory and authentication service). Essentially, Azure AD Connect provides the ability to synchronize Active Directory accounts & groups with Azure AD. While there is some capability to synchronize data from Azure AD to the on-premises Active Directory, this is typically limited to things like password change updates. Note that when an organization signs up for Microsoft 365, an Azure AD environment is automatically created.

**Potential Target**

Smart attackers will take a close look at Azure AD Connect in an on-prem environment and for good reason. Depending on the permissions assigned to the Azure AD Connector account (which should directly correlate with the purpose/scope of the sync) the AD Connect server can, and often will, be a prime target.

Take for instance the default “express” installation of Azure AD Connect. When this option is selected the Connector service account (created in the on-prem AD and prefixed with **MSOL_** ) gets the following permissions:

- Replicate Directory Changes
- Replicate Directory Changes All
- Read/Write all properties User
- Read/Write all properties iNetOrgPerson
- Read/Write all properties Group
- Read/Write all properties Contact
- Reset password

*See the Azure AD Connect Feature Breakdown table at the end of this article for a nice summary on the use case for these rights and how they have the potential to enable an attacker.*

Looking at this list its pretty easy to see why this account would be a highly desired target. If an attacker could control the Connector account, or the AD Connect server where the account is running, it is not hard to imagine a complete compromise of the environment. Sean Metcalf explored concerns with these permissions in his DEFCON (2017) presentation "Hacking the Cloud" (with Taya, @tayatranscends) and went into more detail highlighting how an attacker could leverage these elevated rights with DCSync in his Hybrid Identity Protection (2017) & HackCon (2018) talks.

While the service account or AD Connect server to service account attack methods are likely the most obvious, attention should also be paid to the database hosting Azure AD Connect. Typically, in most installations (including the "express" install) this database is created locally on the Azure AD Connect server with SQL Express LocalDB. However, we have seen organizations that choose to host this on a full SQL instance elsewhere. This is a fully supported method but means that special attention/treatment will need to be given to those SQL servers as identity data for all accounts syncing to Azure AD may reside in that database.

**Mitigate & Defend**

So, we know that the Azure AD Connect server, Connector service account, and database can be leveraged by would-be attackers to fully compromise an environment. Let us take a look at how to better protect these sensitive components.

Be sure the AD Connector service account is PROPERLY permissioned (see the Azure AD Connect Feature Breakdown table at the end of this post for more information).

- Document the features that are approved/desired (organization driven) to be synced with Azure AD. Match the approved features with the necessary rights and ONLY assign those rights. Just because Microsoft "defaults" to the rights previously listed does not mean those are necessary for each and every use case.

- Decide which on-prem AD accounts SHOULD be synced with Azure Active Directory. If admin level accounts and groups do not need to reside in Azure AD, be sure the rights assigned to the Connector account are not applied to those objects, and more specifically the AdminSDHolder object (which propagates to highly privileged accounts).

Treat the Azure AD Connect server as a Domain Controller (i.e. Tier 0). This means minimizing access, rights, and management to only those designated. This also goes for the SQL server hosting the Connect database, if applicable.

- Server(s) should be in a top-level Admin OU.
- GPOs applying to the OU should be managed/owned exclusively by AD Admins (Tier 0) and User Rights Assignments should be implemented appropriately to limit non-Admin access.
- Privileged Access Workstations (PAWs/SAWs) should be used to manage the server(s).
- The local Administrators group should be limited to Domain Admins.

Setup the Connector account as a Group Managed Service Account (GMSA). While the default MSOL account password is both long and complex, it is set to "Never Expire". With GMSAs the account password will automatically rotate on a regular basis.

If Azure AD Connect was installed prior to version 1.1.654.0 be sure to lock down access to the Connector account:

- Disable inheritance on the service account object.
- Remove all access control entries (ACEs) on the service account object, except those specifically for SELF.
- Apply the permissions referenced in Microsoft's article under the *Lock down access to the AD DS account* section.

Ensure the Azure AD Connect version stays current. Microsoft announced in late 2019 that versions older than 18 months are deprecated (so there may be support issues). Trimarc identifies older Azure AD Connect version in most of our Microsoft Cloud Security Assessments (MCSAs) which focus on Azure AD/Office 365.

While not directly related to Azure AD Connect, as these settings are configured in Azure AD, it's imperative to disable legacy authentication and enable MFA (on privileged accounts). Microsoft has an easy to follow How-To article which also spells out the benefits. Notably, organizations where legacy authentication is disabled experience 67% fewer compromises (i.e. this is a big deal).

**Azure AD Connect Feature Breakdown**

The features identified below are optional for an Azure AD Connect deployment. If none of these options are required by the organization then the Connector service account ONLY requires Domain User rights.

| Azure AD Connect Feature | Permission Required | Use Case | Attacker Potential |
|---|---|---|---|
| Device Writeback | • Write permissions on the Registered Devices container<br>• Write permissions on the Device Registration Configuration container | Allows management, such as Conditional Access policies, for devices registered with Azure Active Directory. | Yes, if compromised an attacker gains the ability to bypass Conditional Access polices. |
| Exchange Hybrid Deployment | • Write permissions to multiple attributes for users, groups, and contacts | Allows for the co-existence of Exchange mailboxes between on-prem Exchange and Exchange Online. | Yes, if compromised gives an attacker the capability to modify AD objects that are synced to Azure AD. |
| Exchange Mail Public Folder | • Read permissions to multiple attributes for public folders | Allows for the co-existence (and access) of Exchange public folders between on-prem Exchange and Exchange Online. | Nothing identified at this time. |
| Group Writeback | • Create all Child Objects on the designated OU | Allows for "cloud" created groups to reside in on-prem AD. | Nothing identified at this time. |
| ms-DS-ConsistencyGuid | • Write permissions to the ms-DS-ConsistencyGuid attribute on User objects | Allows for the ms-DS-ConsistencyGuid attribute to be used as the sourceAnchor between on-prem and Azure AD for User objects. | Nothing identified at this time. |
| Password Hash Sync | • Replicate Directory Changes<br>• Replicate Directory Changes All | Allows for password hash data to sync between on-prem and Azure AD. This provides users the ability to authenticate directly with Azure AD. | Yes, if compromised an attacker with these rights can run DCSync to fully exploit the environment. |
| Password Writeback | • Reset password<br>• Write permissions on lockoutTime and pwdLastSet<br>• Extended rights for Unexpire Password | Allows for users to change or unlock their account via the web. Password changes performed online are automatically written back to on-prem AD. | Yes, if compromised an attacker has the ability to reset passwords on all objects synced to Azure AD. |

*Note: These may not be a complete list of the permissions required for each feature. Only the high-level/critical rights were captured.*

### Additional Information

This article's primary focus is on the mitigation and defensive postures needed to protect Azure AD Connect and does not provide a dive deep into the methods currently in use by attackers. With that being said, there are some really great pieces on the web which do the red team perspective proper justice.

- Dirk-jan Mollema's article Updating adconnectdump - a journey into DPAPI; goes into why Azure AD Connect is a potential target (when organizations leverage Password Hash Synchronization) and how the AD Connect database can be exploited.

- Sean Metcalf's presentation at DerbyCon SafeMode (2020) Hacking the Hybrid Cloud; highlights known methods for compromising AD Connect including Pass-Through Authentication (PTA) and Seamless Single Sign-On (an "add-on" component for Azure AD Connect).
- Adam Chester's article Azure AD Connect for Red Teamers; walks through different Azure AD Connect attacks (with instructions).



*By: Scott W Blake*

*Trimarc Security Consultant with 10+ years building, configuring, and securing enterprise environments.*

*Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.*